

Exam Web security – ST 2026

Date: 28.4.2026

Time: 18:00 – 18:45

Duration: 45 min

Location: Room 2.502

Mode: Closed book; no paper required; electronic devices, help by other persons, and groupwork are prohibited!

Example questions:

- 1) What elements does the “origin” of the Same-Origin-Policy of web browsers consist of?
- 2) Are NoSQL databases secure from injection attacks:
 - Yes/No
 - Give a reason/explanation for your answer!
- 3) Explain the difference between whitelists and blacklists and give an example of each!
- 4) Give two reasons why a website might not fix a known security problem immediately. Also explain what you can do in the meantime to prevent successful exploits.
- 5) Explain "Escaping" in the context of web security.
- 6) What is a “path traversal attack”? Give an example!
- 7) What are the effects of starting the name of a Cookie with “__Secure-” or “__Host-”?
- 8) Explain the meaning of “context” in the scope of XSS prevention!
- 9) Why are databases rarely attacked directly and instead usually via the application (e.g. via injection attacks)?
- 10) Explain the difference between marking a Cookie as "secure" with the flag and prefixing its name with “__Secure-” !
- 11) Why should you use CSP, i.e. what is its main advantage/against which kinds of attacks does it help?
- 12) What does the Cookie attribute "sameSite" mean and why is it potentially problematic?
- 13) What is the difference between a normal and a "blind" injection attack? How can we overcome this difficulty?
- 14) Explain the approach to prevent XSS problems!